

# Report – Cracking di Password MD5 con John the Ripper

Per questo esercizio ho simulato un attacco SQL Injection al fine di recuperare alcune password memorizzate all'interno di un database vulnerabile. Le password ottenute non erano in chiaro, ma apparivano come stringhe cifrate in formato hash, apparentemente in MD5. L'obiettivo era quindi quello di decifrarle e risalire al testo originale delle password utilizzando un attacco a dizionario.

Come prima cosa, ho preparato un file di testo contenente tutti gli hash recuperati. Ho creato questo file nella cartella Desktop, nominandolo `hash.txt`, e vi ho inserito le stringhe, una per riga. Alcune di queste si ripetevano, quindi mi aspettavo che anche la password corrispondente si ripetesse una volta decrittata.

Per il cracking ho utilizzato John the Ripper, uno strumento già installato su Kali Linux. Ho verificato anche la presenza del dizionario `rockyou.txt`, che contiene migliaia di password comuni, molto utile per questo tipo di attacchi. Dopo aver confermato che il dizionario era disponibile e decompresso, ho avviato la procedura di cracking specificando a John il tipo di hash (`raw-md5`) e il dizionario da utilizzare.

Durante l'esecuzione, John ha confrontato ogni parola del dizionario con gli hash nel file, riuscendo a decifrare tutte e cinque le password. Infine, ho utilizzato un comando di verifica per vedere le corrispondenze ottenute. Le password decifrate sono risultate essere: `password`, `abc123`, `charley`, `letmein` e di nuovo `password`, confermando la ripetizione attesa.

L'attacco si è rivelato efficace grazie alla semplicità dell'algoritmo MD5, privo di salatura, e all'uso di un dizionario ampio e ben strutturato. L'esperimento ha dimostrato quanto sia importante non affidarsi a password comuni e a sistemi di hashing obsoleti per la protezione dei dati sensibili.

## 1. `sudo apt install wordlists`

Questo comando serve per installare il pacchetto che contiene una serie di dizionari standard, tra cui `rockyou.txt`. Il dizionario è essenziale per eseguire un attacco a dizionario, confrontando migliaia di parole comuni con gli hash.

## 2. `sudo gzip -d /usr/share/wordlists/rockyou.txt.gz`

Il file `rockyou.txt` viene fornito compresso in formato `.gz`. Questo comando lo decomprime, rendendolo utilizzabile da John the Ripper. È una fase obbligatoria prima di poter usare il dizionario nel cracking.

## 3. `ls /usr/share/wordlists/rockyou.txt`

Serve semplicemente a verificare che il file `rockyou.txt` sia presente e accessibile. È una buona prassi prima di lanciare un'operazione che dipende da quel file.

## 4. `nano ~/Desktop/hash.txt`

Utilizzato per creare (o modificare) manualmente il file `hash.txt` contenente gli hash MD5 recuperati. Il file deve contenere un hash per riga, così che John possa leggerlo correttamente.

```
5. john --format=raw-md5
--wordlist=/usr/share/wordlists/rockyou.txt
~/Desktop/hash.txt
```

Questo è il comando principale per eseguire il cracking:

- `--format=raw-md5`: specifica il tipo di hash, in questo caso MD5 puro, senza sali.
- `--wordlist=...`: indica il file di dizionario da usare.
- L'ultimo parametro è il file contenente gli hash.

Con questo comando, John confronta ogni parola del dizionario con ogni hash del file fino a trovare una corrispondenza.

```
6. john --show --format=raw-md5 ~/Desktop/hash.txt
```

Una volta terminata la sessione di cracking, questo comando mostra le password trovate in chiaro accanto ai rispettivi hash. È utile anche per verificare se ci sono hash non ancora craccati.

```
File Actions Edit View Help
ones used instead.
john is already the newest version (1.9.0-Jumbo-1+git20211102-0kali9).
Summary:
  Upgrading: 0, Installing: 0, Removing: 0, Not Upgrading: 1238

(kali㉿kali)-[~/Desktop]
$ sudo apt install wordlists
sudo gzip -d /usr/share/wordlists/rockyou.txt.gz

wordlists is already the newest version (2023.2.0).
wordlists set to manually installed.
Summary:
  Upgrading: 0, Installing: 0, Removing: 0, Not Upgrading: 1238

(kali㉿kali)-[~/Desktop]
$ ls /usr/share/wordlists/rockyou.txt

/usr/share/wordlists/rockyou.txt

(kali㉿kali)-[~/Desktop]
$ john --format=raw-md5 --wordlist=/usr/share/wordlists/rockyou.txt ~/Desktop/hash.txt

Using default input encoding: UTF-8
Loaded 4 password hashes with no different salts (Raw-MD5 [MD5 128/128 SSE2 4x3])
Warning: no OpenMP support for this hash type, consider --fork=8
Press 'q' or Ctrl-C to abort, almost any other key for status
password      (?)
abc123        (?)
letmein       (?)
charley       (?)
4g 0:00:00:00 DONE (2025-05-27 11:56) 200.0g/s 144000p/s 144000c/s 192000C/s
my3kids..soccer9
Warning: passwords printed above might not be all those cracked
Use the "--show --format=Raw-MD5" options to display all of the cracked passwords reliably
Session completed.

(kali㉿kali)-[~/Desktop]
$ john --show --format=raw-md5 ~/Desktop/hash.txt

?:password
?:abc123
?:charley
?:letmein
?:password

5 password hashes cracked, 0 left
```

